POS security, action results, and receipt completion

Resumed and verified 2026-09-24. This review covers POS action boundaries, terminal result hydration, receipt access and delivery evidence, and the missing public receipt page. It does not certify the wider application or replace the separate financial, PostgreSQL, and browser reviews.

Evidence and architecture

The dirty source baseline is preserved in `evidence/baseline/`; new files are identified below. Existing changes were retained. The graph inventory identifies `api_receipts_receiptid_route_ts` and `receiptid_route_get` in community 55 of `graphify-out/graph_app.json`. Current source was inspected because the graph predates the new receipt page.

Authenticated action → permission check/trusted organization and actor → schema/domain service → committed result → best-effort cache refresh. Mutation result truth must survive a failed cache or logging sink.

Public receipt URL → dynamic server page or receipt API → `getPublicSalesReceipt` → signed token verification → registered active token bound to organization and sale → organization-scoped receipt query → public-safe receipt content. The HTML page uses an explicit presentation allowlist and passes only a translated print-button label to its client component. Checking a receipt records access evidence but performs no sale, payment, stock, or ledger operation.

Findings and corrections

ID	Severity	Journey and reproduction	Correction	Verification
SEC-POS-01	High	A saved cart, terminal, offline decision, or receipt revocation can be returned as failed when its subsequent cache invalidation throws. Sale and shift wrappers also allowed a throwing logging sink to replace the committed result.	Shared `revalidatePOSAfterCommit` catches each cache failure independently and guards logging. Cart, offline review, token, sync, terminal, sale, and shift actions use it. Logs omit exception payloads.	Action fault-injection tests preserve the saved result and continue remaining invalidations; sale and shift tests also inject logging failure.
SEC-POS-02	Medium	Cash drawer reads lacked the organization/actor result envelope required by scoped POS read hooks.	`getCashDrawerDashboardAction` returns `POSReadResult` and safe typed read errors.	Drawer action tests cover scoped success and denied/error results. Hook integration is covered in the parent review.
SEC-POS-03	High	`sendReceipt` wrote the full bearer receipt URL into delivery audit changes. Anyone able to read those historical audit values could possess an active receipt credential.	New audit records retain only `digitalReceiptPath`, alongside delivery outcome and order evidence. No raw bearer token is written by this path.	Receipt test extracts the issued token and proves it is absent from audit writes. Historical remediation remains outstanding below.

ID	Severity	Journey and reproduction	Correction	Verification
SEC-POS-04	Medium	Public receipt API and middleware responses could retain the general referrer policy, exposing bearer query strings to subsequent requests and allowing inappropriate storage/indexing.	Receipt HTML/API receive `private, no-store, max-age=0`, `no-referrer`, and `X-Robots-Tag: noindex, nofollow, noarchive`; page metadata also disables indexing and referrers.	API success/error checks; middleware valid paths, prefix exclusions, and rate-denied responses.
SEC-POS-05	Medium	Terminal creation/update committed before the response row was reloaded; failed hydration could report failure despite a saved configuration.	Result hydration occurs within the same database transaction as the terminal write.	`terminal-result-transaction.service.test.ts` verifies transaction-client reads and rejects failed hydration. This is a mocked boundary proof, not a real PostgreSQL rollback proof.
SEC-POS-06	Medium	Receipt service generated `/digital-receipt/<sale>?token=...`, but no corresponding page existed.	Added a dynamic server-rendered EN/FR receipt page, generic unavailable view, browser-native print button, fiscal-state explanation, responsive natural-height content, and no private contact/staff/session/provider diagnostics in rendered HTML.	Page tests cover missing/ambiguous/invalid access, EN/FR content, HTML escaping, private-field exclusion, status truth, printing, and generic transient failure. Valid and revoked token enforcement is independently exercised in the public receipt service/registry suites.
SEC-POS-07	Medium	Public JSON receipt certification copied free-form `rejectionReason` and fiscalization outbox `lastErrorMessage` into customer-visible content.	Public receipts clear rejection details and use a fixed generic message for delivery blocks. Status and blocked flags are preserved. Authenticated diagnostic content is unchanged.	Focused public receipt regression proves raw provider/outbox error text is absent publicly while private diagnostics remain available.

Threat and control matrix

Threat	Current control and evidence	Limit
Cross-tenant or forged actor input	POS actions derive organization/actor from authenticated permission context; terminal management rejects a requested organization different from that context. Action suites verify trusted scope and denials.	Broad role design was not changed.
Unauthorized sale/refund/void	`pos.use`, `pos.transactions.refund`, and `pos.transactions.void` guards; enforced POS module gate; fresh authentication for corrections.	Service transaction correctness is reviewed separately.
Unauthorized token management	`pos.receipts.revoke`, enforced POS module access, and fresh authentication on revocation.	Existing token capability/read permissions are preserved.
Treating observe-mode checks as enforcement	Catalog, drawer, terminal management, and shift-close paths retain documented observe-mode behavior; service-side new-work admission remains separate.	This review makes no claim that every POS surface has enforcement enabled. Changing rollout/access policy needs coordinated policy work.

Threat	Current control and evidence	Limit
Forged, expired, mismatched, revoked, unknown or legacy unregistered receipt token	HMAC verification, sale binding, organization/JTI-bearing token requirement, registry hash lookup, active status and expiry checks.	Token secret provisioning and operational rotation are deployment controls; no secret value was read or changed here.
Receipt enumeration	Missing/invalid access fails before receipt data lookup; unavailable page is generic and bilingual.	Middleware rate limiting is process-local, not a proven shared deployment-wide abuse limit.
Customer/staff data leakage	Public query excludes customer contact/balance and staff email selection; new HTML allowlist additionally excludes cashier, terminal, shift, payment identifiers and operational fiscal diagnostics.	Public JSON retains the existing receipt contract apart from redacted free-form diagnostics; it is accessible to valid bearer holders.
XSS or external referrer leakage	React text rendering, no injected HTML, no page-generated external links/assets, no-referrer metadata and headers.	A bearer link can still be deliberately shared or captured by browser history or infrastructure request logs. Those logging surfaces were not audited or modified in this slice.
False statutory claims	HTML distinguishes purchase summary from fiscal certification; blocked/pending states remain visible; fiscal number appears only for recorded certification with delivery allowed.	No legal, tax, or country-pack certification is asserted.
False delivery success	Existing channel adapters/stubs remain unchanged. Printing is a local browser action, not a provider delivery claim.	Email/SMS/print server stubs and WhatsApp production configuration are not certified by this work.
Duplicate action after response failure	Cache/log failures preserve returned committed results; terminal row hydration is within its write transaction.	Durable sale replay/concurrency is a separate service review.

Changed source and test files versus the saved baseline

New:

- `actions/pos/cache-revalidation.ts`
- `services/pos/__tests__/terminal-result-transaction.service.test.ts`
- `app/digital-receipt/[receiptId]/page.tsx`
- `app/digital-receipt/[receiptId]/not-found.tsx`
- `app/digital-receipt/[receiptId]/PrintReceiptButton.tsx`
- `app/digital-receipt/[receiptId]/__tests__/page.test.tsx`

Changed:

- `actions/pos/cart.actions.ts`, `drawer-dashboard.actions.ts`, `offline-review.actions.ts`, `receipt-token.actions.ts`, `session.actions.ts`, `sync.actions.ts`, `tender.actions.ts`, `terminal-management.actions.ts`
- Corresponding tests in `actions/pos/__tests__/`: `cart-write-access.actions.test.ts`, `drawer-dashboard.actions.test.ts`, `offline-review.actions.test.ts`, `receipt-token.actions.test.ts`, `session.actions.test.ts`, `sync.actions.test.ts`, `tender.actions.test.ts`, `terminal-management.actions.test.ts`
- `app/api/receipts/[receiptId]/route.ts` and `__tests__/route.test.ts`

- `services/pos/receipt.service.ts`, `services/pos/__tests__/receipt-public.test.ts`, `services/pos/terminal-management.service.ts`
- `middleware.ts`, `lib/security/__tests__/middleware-routing.test.ts`

Verification

Run	Result	Evidence
Receipt page/API/middleware/public service/token suites	6 suites, 60 tests passed	`receipt-completion-tests.log`
All 13 POS action suites; seven receipt/terminal service suites; page, API, middleware	23 suites, 177 tests passed	`security-completion-tests.log`
Scoped lint for all changed action, receipt, terminal, middleware and page files	Passed, exit 0	`security-completion-lint.log`
Final public diagnostic redaction	1 suite, 15 tests passed	`receipt-public-redaction-tests.log`
Lint after final diagnostic redaction	Passed, exit 0	`receipt-public-redaction-lint.log`

The final redaction run includes one new case and repeats the existing public receipt cases; these run totals must not be added as distinct tests. The comprehensive parent run is authoritative for the final combined tree. No live charge, refund, void, provider delivery, migration, or access-policy change was performed in this slice. Build/typecheck, real database behavior, and browser viewport/accessibility evidence belong to the parent verification report and are not inferred from Jest.

Residual actions and release limits

1. **Historical bearer credentials:** New audit writes are corrected, but pre-existing receipt URLs may remain in historical audit records/backups. An authorized operator must inventory affected records without exposing tokens, revoke still-active affected receipt tokens, assess log access, and apply the agreed retention/redaction policy with preserved audit provenance. No broad delete, token rotation, or historical mutation was performed. Operational exposure is unresolved until that review completes.
2. **Actual browser coverage:** Unit rendering tests do not prove responsive layouts, print pagination, keyboard use, screen-reader behavior, or accessibility conformance in a real browser. Parent verification must record completed and blocked browser checks honestly.
3. **Terminal database proof:** The terminal transaction tests use a mocked transaction client. They establish code placement but do not certify PostgreSQL isolation or rollback behavior.
4. **Role design:** Terminal mutations currently use the repository's `pos.session.start` permission. This review preserves that policy; introducing a dedicated terminal-configuration permission would require a coordinated role migration and business decision.
5. **Token registry audit coupling:** Existing token registry issue/access/revoke functions perform their audit write after the registry write when used with the default client. An audit failure can cause the call to fail after the registry state changed. Access fails closed, and revocation remains effective; this is a remaining operational result/audit atomicity limitation, not evidence that authorization can be bypassed.

For support, retain the sale/order reference and structured result state, never paste a receipt bearer token into logs or tickets. If a receipt is unavailable, request a newly authorized receipt link from the store. If rendering is

temporarily unavailable, checking again cannot create a sale or payment. Do not infer fiscal certification or external delivery success from a purchase summary.